Cloud Security Posture Review

Use this workbook to learn a repeatable method. Write what you observed separately from what you infer; never present fictional sample data as a real incident or production assessment.

1. Review a design, not a live account

LAB SCOPE Use a fictional architecture or an authorised training tenant. This worksheet does not require creating cloud resources. Provider labs may incur costs; check current pricing and shut down any authorised test resources when finished.

Review field	Learner entry
Service / fictional system	
Data sensitivity and business purpose	
Cloud model / provider (if applicable)	
Reviewer and review date	
Scope and exclusions	
Assumptions / unavailable evidence	

2. Architecture and trust boundaries

Which identities can administer the environment?

Which services are internet-facing, and why?

Where is sensitive data stored and how does it move?

Which events are logged and who can review them?

3. Security-control checklist

Area	Review question	Evidence to request	Status / note
Identity	Least privilege, MFA, named roles, safe recovery?	Role assignments, MFA coverage, privileged sign-in audit	
Network	Ingress/egress limited to business need?	Network rules, diagrams, approved exposure list	
Storage	Private by default; access and encryption reviewed?	Storage policy, access logs, encryption settings	
Secrets	Secrets protected and rotated; no credentials in code?	Secret-store configuration, scan or review results	
Logging	Audit events collected, retained, and retrievable?	Log settings, retention, example event, alert route	
Recovery	Backups protected and restore-tested?	Backup policy, last restore test, access boundary	
Change	Configuration changes reviewed and attributable?	Change record, owner, version history	

4. Prioritise findings

Finding	Evidence and gap	Risk / impact	Recommended treatment	Owner / review

What did this review not test?

What evidence would confirm the highest-priority fix?

DO NOT OVERCLAIM A checklist item marked “done” is not proof by itself. Record the evidence reviewed, the date, and the remaining limitations.

A real lab for these notes

Topic: Identity, network, storage, logging, recovery, and cloud posture findings. These pages connect the existing OpenCyberPath notes to specific provider-hosted exercises. The card label is intentionally generic; the exact task name and direct URL are listed here so you can open the right exercise instead of a whole catalogue.

Concept checkpoints

- Review a fictional architecture or explicitly authorised training tenant.
- Prioritise identity permissions, public exposure, logging coverage, encryption, backups, and recovery.
- Record asset, threat scenario, evidence, likely impact, remediation, owner, and residual risk.
- Cloud subscriptions, workloads, and lab resources can incur charges; never create them casually.

Identify security risks by using Cloud Security Posture Management *[Microsoft Learn]*
https://learn.microsoft.com/en-us/training/modules/identify-security-risks-posture-management/
Access note: Direct guided learning module. A live lab tenant may not be included in every unit; avoid provisioning resources unless you understand the cost.

Manage your cloud security posture management *[Microsoft Learn]*
https://learn.microsoft.com/en-us/training/modules/manage-cloud-security-posture-management/
Access note: Direct module with learning units and assessment. Account and lab access depend on the unit and current provider offer.

ACCESS CHECK Open the exact task page and verify the current login, account tier, VM launch button, free/paid terms, and any cost notes before starting. A provider may change availability or retire a challenge.

Before you click Start

- Write down the provider's target/scope and use only the instance it creates for you.
- Keep this notebook beside the exercise. Use its original course data before trying commands on a local machine.
- Capture timestamps, filenames, row/packet IDs, and a short explanation; redact credentials, tokens, and personal data.
- If a page says retired, premium, or downloadable-only, use the alternative listed in the access note or return to the matching interactive lab above.

Commands you can explain

Cloud CLI examples are optional read-only checks for a lab-issued sandbox only. The default exercise uses the local fictional worksheet and incurs no cloud cost.

First download the matching sample file(s) from the existing card when a command names one. Keep the data in a practice folder and never execute strings stored in evidence.

LOCAL WORKSHEET / SHOW REVIEW ROWS

```
Import-Csv .\cloud-security-posture-checklist.csv | Format-Table -AutoSize
```

Open the bundled fictional checklist; no cloud API is called.

POWERSHELL / PRESERVE CHECKLIST HASH

```
Get-FileHash .\cloud-security-posture-checklist.csv -Algorithm SHA256
```

Record which checklist version was reviewed.

AZURE CLI / CONTEXT CHECK ONLY

```
az account show --query "{name:name,tenantId:tenantId}" --output table
```

OPTIONAL: run only inside the training tenant your instructor/provider supplied. Do not run on a personal or employer account for this exercise.

AWS CLI / IDENTITY CHECK ONLY

```
aws sts get-caller-identity
```

OPTIONAL: run only inside the lab-issued AWS sandbox. It reads identity context and does not create resources; never share account IDs or credentials.

REPORT-ONLY STEP

```
Write down the exact resource identifier and recommendation shown by the assigned module.
```

Do not change permissions or create/delete resources unless the provider's sandbox explicitly instructs it.

COMMAND HABIT Check the current working directory, shell, target, and expected effect before pressing Enter. Save the exact command and the output that mattered.

Guided lab run

- 1. Open the direct Microsoft Learn posture-risk module and note whether it includes an actual sandbox.
- 2. Use the supplied fictional diagram and checklist if no sandbox is available.
- 3. For each issue, write the observed configuration, risk scenario, severity rationale, and recommended change.
- 4. If using a cloud sandbox, verify the active tenant/account name before running any CLI command.
- 5. Do not create or change cloud resources unless the exercise explicitly provisions a sandbox and discloses cost/cleanup instructions.

Evidence checklist

- [ ] What exact lab instance or sample file was used?
- [ ] Which command/query and time range produced the observation?
- [ ] What is the directly observed fact, separate from your inference?
- [ ] What benign/alternative explanation could fit?
- [ ] What extra record or control would help confirm the conclusion?

Check your understanding

Q Is a public storage bucket automatically evidence of a data breach?

Think it through: No. It is an exposure condition; the accessible data, permissions, logs, and access history require investigation.

Q Why record the exact account/tenant before a CLI task?

Think it through: It reduces the chance of accidentally using a personal or paid production account instead of the intended sandbox.

Q Which areas belong in a posture review?

Think it through: Identity, network boundaries, data protection, logs/monitoring, patching, backup/recovery, and governance.

NOTEBOOK CLOSE-OUT Finish with: Observation / Evidence source / Why it matters / Alternative explanation / Next check / Limitation. A careful "not enough evidence yet" is a valid professional result.